

Passwordless Techniques Based on Cryptography

Abstract—Traditional password-based authentication systems suffer from several security and usability limitations, including phishing attacks, credential theft, password reuse, and unauthorized access caused by server-side breaches. As cybersecurity threats continue to evolve, passwordless authentication has emerged as a more secure alternative for protecting digital systems and user identities. This paper presents a passwordless authentication framework that integrates public-key cryptography, biometric verification, and adaptive risk-based authentication mechanisms. The proposed approach eliminates the need for traditional passwords through cryptographic challenge-response verification and secure device-based authentication. During login, biometric verification is used to strengthen identity validation, while a risk-based layer continuously analyzes contextual factors such as device type, login location, and user behavior to detect suspicious activities. The proposed solution improves resistance against phishing, replay attacks, and credential theft while enhancing usability and authentication reliability. Overall, the framework provides a secure, scalable, and user-friendly authentication solution for modern digital environments.

Keywords—Passwordless Authentication, Public-Key Cryptography, FIDO2, WebAuthn, Biometric Authentication, Risk-Based Authentication, Challenge-Response Authentication, Cybersecurity.

I. INTRODUCTION

The internet is growing rapidly, and more people are doing things online. This has shown us that the old way of using passwords to keep things is not good enough. Passwords can be easily compromised through methods such as phishing or brute-force guessing. When passwords are stolen, it can cause significant problems and result in the theft of a large amount of data. People often use the same password for multiple things, which makes it even easier for malicious individuals to gain access. This is why many people are seeking a way to keep things secure without relying on passwords.

This new way is called passwordless authentication. It uses codes and keys to keep things secure, rather than passwords. Standards like FIDO2 are helping to make this method of keeping things safe a reality. Many large companies are already adopting this approach, and it is expected to experience significant growth in the next few years.

This paper looks at the state of passwordless authentication. The rest of the paper is divided into sections. Section II talks about the basics of cryptography. Section III looks at what other people have written about passwordless authentication and finds the gaps in the research. Section IV

proposes a framework for authentication. Sections V, VI, and VII discuss the findings, what we learned, and what we think should happen next.

A. Problem Statement

After many years of trying to make passwords safer, they are still the main way people log in to things. The problem with passwords is that they can be used multiple times, given to someone else, and stored in one place, which makes them easy to steal. When a company's database is hacked, it can expose millions of passwords at once. There are some solutions, like two-factor authentication, that can help, but they do not get rid of the password completely. We need a solution that is safe, easy to use, and does not use passwords at all. This is what motivated us to do this research.

B. Research Methodology and Structure of the Research

This study conducts a systematic literature review on the use of cryptography in the field of passwordless authentication. The purpose of the review is to list existing authentication methods, assess their security pros and cons, and to discover research gaps in the literature. 24 peer-reviewed articles were selected based on their relevance to cryptographic authentication mechanisms and the current state of the art in the field. The main findings are presented in Section III, which are further organized in comparative tables in the gap analysis to provide a clear systematic evaluation of the methods reviewed.

II. BACKGROUND

A. Traditional and Passwordless Authentication

The traditional password authentication method is prevalent in the modern digital platforms but has many security issues like credential theft, brute force attack, password re-use, and phishing attack [1]. Even more, the centralized password databases are susceptible to unauthorized access and leakage on the server side. In order to solve the problems mentioned above, passwordless authentication has emerged as an alternative authentication technology which replaces passwords with cryptographic authentication technologies and trusted user devices [2]. This can enhance security and minimise reliance on re-usable credentials.

B. Public-Key Cryptography

Public-key cryptography is an essential part of the authentication systems that do not use passwords. It uses

asymmetric cryptography with each user having a public-private key pair. The public key is kept at the authentication server, and the private key is securely kept in the trusted device of the user [3]. When it comes to the authentication server, it creates a challenge number, which is digitally signed with the private key. The server then challenges the client to submit the signature for verification with a public key it holds, which is the one that corresponds to the private key used by the client. This will help to enhance the security against phishing, replay attacks and credential theft as the private key remains on the user device.

C. FIDO2 and WebAuthn

FIDO2 is among the most popular standards that are used to support passwordless authentication. It combines WebAuthn and the Client-to-Authenticator Protocol (CTAP) to provide secure authentication mechanisms [4]. WebAuthn allows websites and apps to authenticate users with cryptographic credentials, and CTAP allows the communication between authenticators and trusted user devices. FIDO2 also minimizes the chances of credential reuse and phishing attacks, as authentication credentials are tied to specific websites, utilizing cryptographic binding. FIDO2 minimizes the chances of credential reuse and phishing attacks, as authentication credentials are cryptographically bound to specific websites.

D. Biometric Authentication

Biometric authentication is frequently embedded in passwordless systems, enhancing identity verification and user-friendliness. The technologies that include fingerprint and facial recognition enable users to prove their identity secure without remembering password [2]. Biometric data is now transferred to devices in a secure environment, ensuring that unauthorized users cannot access credentials and device data.

E. Security Threats in Authentication Systems

Every authentication system is subject to ongoing cybersecurity risks such as phishing attacks, replay attacks, credential theft, credential stuffing, brute force attacks and man in the middle attacks [1]. These threats are a big problem in traditional password-based systems as attackers can get hold of the passwords, either by visiting malicious websites or accessing stolen databases. These can be mitigated by passwordless authentication, which is based on cryptographic challenge-response verification and trusted device-based authentication mechanisms [3].

III. LITERATURE REVIEW

The shift from password based to passwordless authentication has gained considerable momentum in the late years, driven by the fear of new and upcoming cyberthreats. This section reviews 20 key studies that examine The Passwordless Techniques Based in Cryptography evaluating passkeys as a consumer facing replacement for passwords [6], proposing new multi-factor passwordless prototypes [7] conducting a systematic review of the wide range of passwordless techniques found within different industry [7][8], and providing structured and comparative analyses of the competing technologies that presently exist in the field [10]. Together these establish the theory and technical part for this research

George's [6] analysis of passkey technology is complete and includes a comprehensive study of how passkeys differ from textual passwords. The study consists of an examination

of the various strengths and weaknesses of passkeys compared to traditional passwords.

In terms of security, passkeys provide: (1) no vulnerability to phishing attacks due to the elimination of stolen passwords, (2) a virtually impossible target for offline brute force attacks because signs created via passkeys are valid only within the current user session, and (3) no single point of failure through the use of centralized password databases.

In terms of usability, passkeys: (1) eliminate the problem of password fatigue, (2) reduce help-desk costs associated with forgetting passwords, and (3) support seamless single-sign on through compliance-based services.

Oduguwa and Arabo [7], however, adopt a highly pragmatic methodology in designing, developing, and testing their proposed passwordless authentication prototype named Sesame Auth (SA). The architecture of this scheme comprises a client-server framework. While registering, the system creates an RSA key pair of size 2048 bits per account; the public key is shared with the server while the private key is kept encrypted inside the secure storage enclave of the device (Android Keystore or iOS Keychain).

As a remedy to one of the major vulnerabilities of passwordless authentication, namely account recovery, SA employs the technique of steganography where an encrypted user typing ID and the corresponding account public key are hidden inside a file image provided by the user. Several shortcomings are reported in [7]; for example, although using LSB steganography makes implementation easy, this method can be detected via various techniques of steganalysis. However, according to the authors, this does not pose any security risks, as the embedded user typing ID is always encrypted; still, there is always a risk of denial-of-service attacks should the stego-image be altered.

Article by Yasasve et al. [8] provides a systematic review that places passwordless authentication in the larger framework of enterprise identity and access management.

The introduction starts by introducing the concept of password authentication as inherently problematic. Apart from its vulnerability to phishing attacks and brute force attempts, the authors point out that the human element is itself part of the problem – such as password reuse, the predictability of passwords, and the stress on users. What sets [8] apart is its design of a reference architecture for a passwordless authentication model that is enterprise friendly.

A major disadvantage of [8] is the hypothetical nature of the architecture presented. There are no deployments or studies carried out with actual users, and the simulation results come from a Flask-based prototype in a simulated environment rather than in a real-world setting.

In paper [9], the authors have identified more than 81 papers published from 2020-2024. In paper [9], the authors identify the attacks on security that passwordless systems help in defending against. These include social engineering, session hijacking, spoofing, credential stealing, denial of services, malware attacks, and biometric attacks. For each of these attacks, the authors discuss the particular type of passwordless system that defends against them. Paper [9] focuses on the following aspects: practical application and evaluation, scalability, security analysis, improvement in efficiency, and AI-based and machine learning-based authentication.

Paper [10] identifies and evaluates eleven existing and upcoming passwordless authentication technologies along

three important dimensions of security, cost, and usability, creating perhaps the most practically applicable framework among recent papers. The considered technologies range from lighter weight techniques (email OTP, SMS OTP, and magic links) to more traditional secondary factor authentication (TOTP, HOTP, and push notifications) to more secure methods (biometric authentication such as fingerprints, eye scans, and voice recognition, as well as certificate-based authentication and FIDO2). Furthermore, paper [10] does not investigate the combination of the technologies listed above in multi-factor or hybrid configurations, which is becoming increasingly common in enterprise security practices. However, the comparison approach employed in paper [10] provides a useful way to comprehend the decision space within which any passwordless technique must operate.

After the basic problems of password-based security discussed in previous sections, the transition to passwordless authentication has been widely adopted in academia and industry. Spafford [11] was one of the first to address the weakness of user-chosen passwords in a formal manner, and Kovalan et al. [13] later confirmed in a systematic review that poor authentication practices are still common among internet users, even after decades of awareness campaigns. This long-standing gap between known vulnerabilities and user behavior has stimulated the research community to investigate alternatives that completely eliminate the password from the authentication process [12][15].

Cryptography has become one of the cornerstones of this transformation. Czeski et al. [16] laid an important groundwork by showing how cryptographic protocols can greatly improve user authentication in principle, a line of work that has been formalized further by Fett, Küsters, and Schmitz [17] with a rigorous security analysis of the WebAuthn model. Hanzlik, Loss, and Wagner [18] extended this line of work into the FIDO2 ecosystem, formalizing privacy and revocation guarantees for token-based authentication. The practical deployment of such systems, however, introduces usability challenges that purely theoretical work does not fully address. Mustafa et al. [19] performed an empirical evaluation of a push-based passwordless model, showing that public-key cryptography can be used in a way that is both secure and usable for users, while Bicakci, Sekmen and Uzunay [20] addressed the specific issue of passkey recovery in an enterprise setting with a peer-assisted mechanism that balances security and operational practicality.

In addition to stand-alone authentication systems, integration to larger identity management ecosystems has been investigated. Mahnamfar, Bicakci and Uzunay [21] proposed ROSTAM, a passwordless single sign-on architecture that is resilient to server-side breaches, but compatible with existing federated identity systems. Mitra et al. [22] addressed the portability problem with TUSH-Key, allowing user secrets to be securely transferred from hardware key to hardware key without losing isolation. Von Ahn et al. [14] contributed an orthogonal but related mechanism through CAPTCHA, reinforcing the human-versus-machine boundary that underpins many authentication systems. Latest developments have expanded the application domains of passwordless authentication. Wiraatmaja and Kasahara [23] presented a privacy-oriented anonymous authentication scheme based on zero-knowledge proof on distributed ledger technology, whereas Kommuri and Shaik [24] reviewed passwordless authentication techniques for use in IoT applications that need light-weight solutions due to resource limitations.

Manoharan [25] discussed the relationship between

passwordless and two-factor authentication for cloud-based SaaS applications, in which concepts of zero trust and behavioral biometrics were applied to form a holistic security model. This literature indicates that research on passwordless authentication is not an obscure field anymore; rather, it has become a rapidly developing domain involving cryptography, user interface design, distributed computing, and IoT.

A. Gap Analysis

This section presents a critical comparative analysis of the reviewed literature on passwordless authentication techniques based on cryptography. The studies are grouped into three thematic areas: (A) general passwordless and passkey techniques, (B) cryptographic protocol and WebAuthn-based techniques, and (C) SSO integration, key portability, and specialised domain applications. Comparison tables are provided for each group, evaluating approaches across technique, performance/outcome, and limitations.

a. General Passwordless and Passkey Techniques

Table I compares five studies that evaluate or implement general passwordless techniques including passkeys, RSA-based prototypes, systematic reviews, and comparative technology frameworks.

TABLE I. GENERAL PASSWORDLESS AND PASSKEY TECHNIQUE ANALYSIS.

REF	APPROACH	KEY TECHNIQUE	PERFORMANCE / OUTCOME	LIMITATIONS
[6]	Passkey Evaluation (George, 2024)	FIDO2-based passkeys replacing text passwords	No phishing vulnerability; eliminates offline brute-force; removes single point of failure in centralized DBs	Adoption barriers remain; ecosystem maturity varies across platforms
[7]	Sesame Auth – RSA + Steganography (Oduguwa & Arabo, 2024)	2048-bit RSA key pair + LSB steganography for account recovery	Covers account recovery gap; private key secured in Android Keystore / iOS Keychain	LSB steganography detectable via steganalysis; DoS risk if stego-image is altered
[8]	Enterprise Passwordless Reference Architecture (Yasasve et al., 2026)	FIDO2/WebAuthn enterprise model reviewed systematically	Addresses human-element risks (reuse, predictability); enterprise-friendly architecture	Flask prototype only; no real-world user study; hypothetical deployment
[9]	Systematic Review of Passwordless Defences (Yusop et al., 2025)	Review of 81+ papers (2020–2024) on passwordless attack-defence mapping	Maps defences against social engineering, session hijacking, spoofing, DoS, biometric attacks	Descriptive only; no unified implementation or empirical validation
[10]	Comparative Passwordless Technology Framework (Prasad, 2024)	Evaluates 11 technologies (OTP, TOTP, HOTP, biometrics, FIDO2, certs) on security/cost/usability	Practically applicable decision framework for organisations	Does not evaluate hybrid/multi-factor combinations; no empirical testing

As shown above in Table I, although passkey-based solutions [6] overcome inherent vulnerabilities related to phishing attacks and brute force attacks in passwords, there are obstacles in the adoption process caused by the lack of maturity of the ecosystem. While Sesame Auth [7] uses a combination of RSA encryption and steganography to solve the problem of account recovery, an issue faced in nearly all passwordless solutions, it has a drawback of being detectable due to using LSB steganography. These systematic reviews [8][9] give an overview of all available literature but do not provide any validation on their implementation. The proposed

decision-making approach [10] is very useful in practice, yet does not provide empirical data for hybrid solutions.

b. Cryptographic Protocol and WebAuthn-Based Technique

Table II examines studies focused on the cryptographic foundations and formal security analysis of passwordless systems, particularly those based on FIDO2 and WebAuthn standards.

TABLE II. CRYPTOGRAPHIC PROTOCOL AND WEBAUTHN TECHNIQUE ANALYSIS

REF	APPROACH	KEY TECHNIQUE	PERFORMANCE / OUTCOME	LIMITATIONS
[16]	Cryptographic Protocol Strengthening (Czeski et al., 2012)	Foundational cryptographic protocol enhancements for user authentication	Demonstrated theoretical feasibility of cryptography-based user authentication	Theoretical only; no empirical user study; pre-dates modern WebAuthn standards
[17]	WebAuthn Security Model (Fett, Küsters & Schmitz, 2018)	Formal security analysis of the WebAuthn standard	Rigorously proved security properties of WebAuthn authentication flow	Limited to the standard's specification; real-world implementation flaws not addressed
[18]	FIDO2 Privacy & Revocation Formalisation (Hanzlik, Loss & Wagner, 2023)	Formal model for privacy and revocation in FIDO2 token-based authentication	Proved privacy and revocation guarantees for hardware tokens in FIDO2	Hardware-token focus; applicability to software-based authenticators unclear
[19]	Push-Based Passwordless Evaluation (Mustafa et al., 2026)	Public-key cryptography in a push-notification authentication model; empirical usability study	Demonstrated secure and usable authentication via push mechanism	Limited deployment scale; specific to push notification paradigm
[20]	Peer-Assisted Passkey Recovery (Bicakci, Sekmen & Uzunay, 2025)	Enterprise FIDO passkey recovery with peer-assistance for usability-security balance	Practical recovery mechanism for lost/stolen authenticators in enterprise settings	Relies on trusted peers; scalability in large organisations not fully evaluated

Table II shows how the field evolves from basic cryptography theories [16] to more formal security models [17][18]. The formal verification of the security model for WebAuthn [17] was successful in proving the authentication properties of the standard but did not take into account possible implementation flaws that can occur in reality. The FIDO2 privacy and revocation formalization [18] expands on the WebAuthn approach by focusing on token-level privacy but has hardware limitations that make its conclusions applicable only in software authenticators. The usability analysis in [19] represents an important addition to the list of research studies because it connects theoretical security with practical usability. Another significant development is the peer-to-peer recovery solution proposed in [20], which provides a solution to the important issue of credential loss in an enterprise setting. One of the common drawbacks among all these studies is their focus on either security or usability issues.

c. SSO Integration, Key Portability, and Specialised Domain Applications

Table III analyses studies that extend passwordless authentication beyond standard desktop/web contexts into single sign-on (SSO) architectures, hardware-key portability,

distributed ledger applications, IoT environments, and cloud-based SaaS systems.

TABLE III. SSO, KEY PORTABILITY, AND DOMAIN-SPECIFIC TECHNIQUE ANALYSIS

REF	APPROACH	KEY TECHNIQUE	PERFORMANCE / OUTCOME	LIMITATIONS
[21]	ROSTAM – Passwordless SSO (Mahnamfar, Bicakci & Uzunay, 2024)	Server-breach-resilient SSO integrated with federated identity and credential managers	Resistant to server-side breaches; backward-compatible with federated identity systems	Complex integration; limited evaluation in heterogeneous enterprise environments
[22]	TUSH-Key – Portable Hardware Secrets (Mitra et al., 2024)	Secure transfer of user secrets across hardware keys without isolation loss	Solves hardware-key portability problem; maintains strong isolation guarantees	Hardware dependency; cost and physical logistics of key replacement not addressed
[23]	Anonymous Auth via Zero-Knowledge Proof (Wiraatmaja & Kasahara, 2025)	Privacy-preserving anonymous authentication on distributed ledger using ZKP	Strong anonymity; decentralised and privacy-focused approach	Scalability and computational overhead of ZKP on ledger not fully evaluated
[24]	IoT Passwordless Authentication (Kommuri & Shaik, 2025)	Lightweight passwordless techniques for resource-constrained IoT devices	Addresses IoT-specific resource limitations in authentication design	Limited generalisability to non-IoT environments; lightweight trade-offs reduce some security guarantees
[25]	MFA+ Passwordless for Cloud (Manoharan, 2025)	Zero-trust and behavioural biometrics combined with passwordless MFA for cloud SaaS	Holistic cloud security model; integrates behavioural signals for adaptive authentication	Behavioural biometric accuracy depends heavily on data quality; privacy concerns not fully resolved

Table III shows that as the implementation of passwordless authentication evolves into more specialized areas, fresh problems arise within these specialized areas. While ROSTAM [21] ensures breach-resistance for server breaches in SSOs, its use in diverse and heterogeneous environments remains problematic due to issues related to integration. On the other hand, TUSH-Key [22], which addresses the important issue of making hardware keys portable, has problems with logistics and associated costs. The anonymous authentication method based on zero-knowledge proof [23] is useful in terms of privacy in distributed computing systems, although there are worries regarding computational efficiency and ledger scalability. The IoT-related solutions [24], on the other hand, have inherent issues with some aspects of security due to limited resources. Lastly, the SaaS cloud approach [25], which merges zero trust and behavioral biometrics, suffers from privacy issues.

d. Summary of Identified Gaps

When we look at the information in Tables I–III we can see that there are some problems with the way passwordless authentication using cryptography is being studied.

There is no check of how secure and easy to use these systems are. Most of the time security and usability are looked at separately. A few studies, like the one in [19] look at both security guarantees and how users really experience the system in a single framework. If someone loses their device or it gets damaged it is hard to get into their account. [7] And

[20] have come up with ways to recover accounts but these ways have some big problems. They can be hard to detect or do not work well with a lot of users.

We do not know much about how different authentication methods work. Even though companies are starting to use passwordless and multi-factor authentication studies like [10] only look at each technology by itself and do not see how they work as a team. We also do not know if these systems can handle a lot of users. Some studies, like [21] [23] and [25] propose systems but do not show that they can work well with many users or a lot of traffic.

Another problem is that many systems only work on one type of device or platform. We need to make sure that these systems work on different devices and platforms but this is rarely checked. Finally, systems that use behavioral data like the one in [25] raise some big concerns, about privacy that have not been fully addressed.

These problems show why we need a solution, which we talk about in Section IV. This solution uses FIDO2. Combines biometric verification, cryptographic challenge-response authentication and adaptive risk-based analysis to make a system that is both secure and easy to use.

IV. PROPOSED SOLUTION

This section describes the proposed passwordless authentication framework based on cryptographic techniques. The proposed solution is to increase security and usability by removing the traditional passwords and replacing them with a secure authentication mechanism based on public-key cryptography, biometric verification and risk-based authentication [2], [3].

The proposed framework combines FIDO2/WebAuthn standards with device-based authentication and dynamic risk analysis to tackle common attacks such as phishing, credential theft, replay attacks, and server-side database breaches [1], [4].

A. Proposed Architecture



Fig. 1. Proposed PASSWORDLESS AUTHENTICATION FRAMEWORK ARCHITECTURE.

The workflow of the proposed passwordless authentication framework is illustrated in Fig. 1. The

framework includes several components, including biometric verification, cryptographic authentication, challenge-response verification, and a risk-based authentication engine. The proposed architecture does not use traditional passwords and improves resistance against phishing, replay attacks, and credential theft [1], [3].

The authentication process starts when the user tries to log in to the system via a browser or a mobile app. The first step of the framework is to verify the user's identity by scanning their fingerprint or face to ensure that the device is being used by the correct owner.

Once the biometric verification is successful, the authenticator creates and controls the public-private key pair. The private key is kept on the user device, while the public key is linked to the authentication server [2], [4].

The server then creates a cryptographic challenge, which during the challenge-response authentication process is digitally signed by the private key. Once the digital signature is verified, the request is passed on to the risk-based authentication engine, which analyzes contextual elements like login location, device data, and user activity to make a final access decision [3], [5].

B. Registration Phase

During the registration phase, the user registers an account using a trusted device such as a laptop or smartphone. The proposed system generates a unique public-private key pair using public-key cryptography techniques [2], [3].

The private key is securely stored on the user device using secure storage technologies such as Android Keystore or Apple Secure Enclave, while the public key is transmitted and stored on the authentication server [4].

To enhance security, the system also requires biometric enrollment such as fingerprint or facial recognition. This ensures that only the legitimate device owner can initiate future authentication requests [2], [5].

In addition, the framework associates the generated credentials with the registered device to reduce unauthorized access attempts from unknown devices.

TABLE IV. REGISTRATION PHASE PROCESS

Step	Process	Security Purpose
1	User creates a new account	Initiates secure device registration
2	System generates public-private key pair	Eliminates reusable password dependency
3	Private key stored securely on device	Protects credentials from server breaches
4	Public key stored on authentication server	Enables secure cryptographic verification
5	User enables biometric verification	Strengthens identity authentication
6	Trusted device linked with user account	Reduces unauthorized access attempts

Table IV summarizes the registration phase of the proposed passwordless authentication framework. The process demonstrates how cryptographic key generation, biometric enrollment, and trusted device registration are integrated to

establish secure user authentication without relying on traditional passwords.

C. Authentication Phase

In the authentication phase, the user tries to access the system using a registered and trusted device. Unlike traditional authentication systems [1], the proposed framework does not require passwords during login.

The authentication server generates a random cryptographic challenge and sends it to the user device through the browser or mobile application. The system requires biometric verification such as fingerprint or facial recognition to verify the user identity before responding to the challenge [2], [4].

After successful biometric verification, the generated challenge is signed using the private key securely stored inside the device. The signed response is sent back to the authentication server. Finally, the server verifies the digital signature using the stored public key [3], [5].

If the verification process is successful, the user is allowed to access the system. Otherwise, the authentication request is rejected. After successful authentication and signature verification, the server generates a secure session token that enables the user to access protected resources without re-authenticating during the active session [26].

TABLE V. AUTHENTICATION WORKFLOW PROCESS

Step	Authentication Action	Security Outcome
1	User submits authentication request	Initiates secure login
2	Server generates random challenge	Prevents replay attacks
3	Biometric verification performed	Confirms user identity
4	Private key signs challenge	Ensures authentication legitimacy
5	Server verifies digital signature	Confirms valid authentication
6	Session token generated	Grants secure system access

Table V summarizes the authentication workflow of the proposed framework. The process combines biometric verification, cryptographic challenge-response authentication, and secure session generation to improve both authentication security and usability.

TABLE VI. SECURITY COMPARISON BETWEEN TRADITIONAL AND PROPOSED AUTHENTICATION SYSTEMS

Security Feature	Traditional Password Authentication	Proposed Passwordless Framework
Password Requirement	Required	Not Required
Phishing Resistance	Low	High
Replay Attack Protection	Limited	Strong
Credential Theft Risk	High	Very Low
Server Database Exposure	High Risk	Reduced Risk
Biometric Verification	Optional	Integrated

User Convenience	Medium	High
Authentication Method	Password-Based	Cryptographic Challenge-Response

Table VI presents a comparison between traditional password-based authentication systems and the proposed passwordless authentication framework. The comparison highlights the security and usability improvements provided by cryptographic authentication, biometric verification, and challenge-response mechanisms.

D. Risk-Based Authentication

To enhance security, a layer of security is added in the proposed framework that continuously monitors the login behavior of users and grants access to the system based on the risk level [3].

The proposed framework evaluates multiple contextual and behavioral factors during each login attempt, unlike traditional authentication systems, which only rely on passwords. These factors include device type, geographic location, IP address, login time, and user behavioral patterns.

The framework uses a combination of behavioral and environmental factors to determine a dynamic risk score. When the calculated risk exceeds a preset adaptive threshold, extra authentication steps are automatically initiated before access is granted [3], [9], [27].

This is an adaptive security solution which significantly lowers unauthorized access attempts and strengthens security against account hijacking and identity theft attacks.

TABLE VII. RISK FACTORS EVALUATED BY THE PROPOSED AUTHENTICATION FRAMEWORK

Risk Factor	Example	Security Action
Unknown Device	Login from unregistered laptop	Additional biometric verification
Suspicious Location	Login from different country	Temporary authentication restriction
Unusual Login Time	Login at 3:00 AM	Risk score increased
IP Address Change	Different network detected	Additional identity verification
Multiple Failed Attempts	Repeated login failures	Temporary account lock

Table VII summarizes the risk factors evaluated by the proposed authentication framework. The adaptive risk analysis mechanism improves overall system security by dynamically identifying suspicious login behavior and reducing unauthorized access attempts.

E. Security Features

The proposed passwordless authentication framework brings together several security mechanisms to enhance authentication security, user identity protection, and the overall reliability of the system. The proposed framework is different from traditional password-based authentication methods because it combines cryptographic authentication, trusted device verification, biometric verification, and adaptive risk analysis to create a more secure authentication environment [1], [2].

The framework provides authentication integrity since it uses public-key cryptography and challenge-response mechanisms instead of reusable passwords [3]. In addition, device-based authentication and biometric verification improve access control by verifying authentication requests from legitimate users and trusted devices [4].

Adaptive risk-based authentication is also integrated into the framework, allowing it to evaluate contextual and behavioral factors during login attempts. This enables the system to dynamically respond to suspicious activities and apply additional verification measures when abnormal behavior is detected [3], [9], [27].

TABLE VIII. SECURITY FEATURES OF THE PROPOSED FRAMEWORK

Security Feature	Purpose
Biometric Verification	Confirms legitimate user identity
Device-Based Authentication	Restricts unauthorized devices
Risk-Based Authentication	Detects suspicious login behavior
Public-Key Cryptography	Secures authentication credentials
Challenge-Response Verification	Enhances authentication integrity

Table VIII summarizes the primary security features integrated into the proposed passwordless authentication framework. These mechanisms collectively improve authentication security, strengthen user identity protection, and enhance system reliability through cryptographic verification, trusted device authentication, and adaptive risk analysis.

F. Practical Implementation

The proposed framework can be implemented as a web-based or mobile authentication system using modern authentication technologies such as FIDO2, WebAuthn, and Python cryptographic libraries [4], [5], [26].

The implementation relies on public-key cryptography and challenge-response authentication to simulate secure passwordless authentication procedures.

Algorithm 1 presents the basic authentication workflow implemented in the proposed framework using WebAuthn-based challenge-response authentication [26].

The implementation demonstrates how cryptographic authentication mechanisms can be integrated into modern authentication systems to provide secure and passwordless user verification.

ALGORITHM 1

Proposed Passwordless Authentication Process

Algorithm 1: Passwordless Authentication Process
Input: User device, authentication server
Output: Authentication decision

1. User initiates login request.
2. Authentication server generates a random challenge.
3. The challenge is sent to the registered user device.
4. User completes biometric verification.
5. The device signs the challenge using the private key.
6. The signed challenge is sent back to the server.
7. The server verifies the signature using the stored public key.
8. If the signature is valid:
Grant access.
Else:
Deny access.

The proposed algorithm depicts the steps in the passwordless login process. To do this, the authentication server first constructs a random challenge and subsequently transmits it to the user device that is registered with the authentication server. Once the biometric verification is achieved the device signs the challenge with the private key stored on the device and returns the signed response to the server.

Server verifies digital signatures by checking the public key associated with the registered device. If valid, then the user is granted access to the system. Otherwise, it will not be allowed. This process helps to enhance the security of authentication and minimizes the risks associated with conventional password-based authentication systems.

G. Advantages of the Proposed Solution

The proposed authentication system has some advantages compared to traditional password-based authentication systems. It removes the need for users to remember and create passwords, which makes the system easier to use and reduces password reuse problems [1], [2].

Secondly, public-key cryptography improves security because private keys stay stored on the user's device instead of being sent to the authentication server [3].

This helps reduce the effect of database breaches and credential theft attacks on the server. The framework also improves protection against phishing and replay attacks by using cryptographic challenge-response authentication [4], [5].

Moreover, biometric verification adds another level of security by helping verify the identity of the user. The framework also includes a risk-based authentication mechanism that checks login behavior and surrounding conditions before giving access to the system [3], [9], [27]. Overall, the proposed framework focuses on improving authentication security while keeping the system easier and more practical for users in modern digital environments.

V. DISCUSSION AND ANALYSIS

Unlike traditional password-based systems, the proposed passwordless authentication framework uses cryptographic authentication mechanisms to maximize security and usability. It combines public-key cryptography, biometric verification, and adaptive risk-based authentication to address several weaknesses associated with traditional systems such as reusable passwords and centralized credential storage.

Proposed framework resistance to phishing attacks. Traditional password-based systems rely on users' credentials, making them targeted for hackers with techniques such as social engineering or malicious phishing pages that appear legitimate. However, the proposed framework uses cryptographic challenge-response authentication, where authentication depends on digital signatures generated locally on the trusted user device. Since private keys are never transmitted to the server, attackers cannot obtain them even if the communication channels are hacked.

The framework also protects the system against replay attacks and server-side breaches, where each authentication request is associated with a unique server-generated challenge, ensuring that previously authenticated responses cannot be reused. Additionally, unlike traditional systems that store password hashes in centralized databases, the proposed solution stores only public keys on the authentication server, so attackers cannot take corresponding private keys or impersonate legitimate users.

Also, it uses biometric verification to strengthen identity assurance by ensuring that only the legitimate device owner can authorize authentication requests. At the same time, the adaptive risk-based authentication engine continuously evaluates contextual factors such as login location, device information, IP address, and behavioral patterns, improving both security and user convenience.

The proposed framework eliminates the need for users to memorize and manage multiple passwords, which makes it much easier than the traditional one, enabling faster login while maintaining strong security guarantees aligning with recent studies that emphasize the growing adoption of FIDO2 and WebAuthn technologies in modern authentication systems [9], [17], [18].

Although the powerful advantage is there, several limitations exist, including that the proposed framework depends heavily on trusted user devices and secure hardware environments such as Android Keystore and Apple Secure Enclave. If a device is lost, damaged, or compromised, account recovery and secure credential migration become challenging problems, which makes biometric data not secure.

VI. FINDINGS AND FUTURE WORK

This research identified several important findings of using a passwordless authentication framework that uses cryptographic First, the study confirmed that traditional password-based authentication systems have many security weaknesses, making them vulnerable to multiple attack types, including phishing attacks, password reuse, credential theft, and server-side database breaches.

Second, the literature review and gap analysis showed that passwordless authentication frameworks based on public-key cryptography provide stronger resistance against common cyberattacks. Technologies such as FIDO2 and WebAuthn improve authentication security by replacing reusable passwords with cryptographic challenge-response mechanisms.

Third, the integration of biometric verification and adaptive risk-based authentication improves identity assurance and system reliability. And behavioral analysis and contextual risk evaluation allow authentication systems to dynamically modify security requirements according to detected login behavior and environmental conditions.

The proposed framework also provides both strong security guarantees and improved user experience. Since users no longer need to memorize complex passwords and change them dynamically, this reduces human error and simplifies the authentication process.

Although the proposed framework provides several advantages, additional research is still required to address existing challenges in passwordless authentication systems. Future work may focus on improving secure account recovery mechanisms without weakening authentication security.

Future studies also may integrate artificial intelligence and machine learning techniques in the proposed framework to adapt to new developments in the cybersecurity environment and practically implement them in a real-world environment to evaluate and measure the scalability, usability, and performance of the proposed framework.

VII. CONCLUSION

This paper presented a study of passwordless authentication techniques based on cryptographic mechanisms and modern authentication standards such as FIDO2 and WebAuthn. The research examined the weaknesses of traditional password-based authentication systems, including phishing attacks, credential theft, password reuse, replay attacks, and server-side database breaches, and to solve this vulnerability, a passwordless authentication framework was proposed.

The framework combines public-key cryptography, biometric verification, and adaptive risk-based authentication to provide secure and user-friendly authentication without relying on traditional passwords. The proposed architecture ensures that private cryptographic keys are stored securely on trusted user devices, while authentication requests are verified using digital signatures.

The analysis demonstrated that the proposed framework provides stronger protection against common authentication attacks while improving usability and reducing dependence on credentials.

The findings of this research indicate that passwordless authentication represents a significant advancement in modern cybersecurity practices. By eliminating passwords and replacing them with cryptographic authentication mechanisms.

Although the challenges in that model, including the dependency on the trusted user devices and the complexity of account recovery, passwordless authentication technologies continue to rapidly be used and improve, they are expected to play an important role in the future of secure digital identity management.

REFERENCES

- [1] L. Lassak, E. Pan, B. Ur, and M. Golla, "Why Aren't We Using Passkeys? Obstacles Companies Face Deploying FIDO2 Passwordless Authentication," in *Proc. 33rd USENIX Security Symposium*, Philadelphia, PA, USA, Aug. 2024.
- [2] A. Carroll and S. Latifi, "Comparative Analysis of Passkeys (FIDO2 Authentication) on Android and iOS for GDPR Compliance in Biometric Data Protection," *Electronics*, vol. 14, no. 20, Art. no. 4018, Oct. 2025, doi: 10.3390/electronics14204018.
- [3] M. A. Al Kabir and W. Elmedany, "Adaptive Risk-Based Passwordless Authentication: A FIDO2 Integrated Approach for Enhanced Security and Usability," *SSRN Electronic Journal*, 2024, doi: 10.2139/ssrn.4795401.
- [4] H. Ravilla, P. P. Kulkarni, and R. Sayal, "Study and Analysis of FIDO2 Passwordless Web Authentication," in *Advances in Computational Intelligence and Informatics*, R. R. Chillarige et al., Eds., *Lecture Notes in Networks and Systems*, vol. 993, Singapore: Springer, 2024, pp. 375-385, doi: 10.1007/978-981-97-4727-6_38.
- [5] V. Kotiya, "FIDO2 Password-less Authentication: Security-Usability Continuum," *CPEN 542 Cybersecurity*, Master of Engineering Leadership, University of British Columbia, Vancouver, BC, Canada, Nov. 2024.
- [6] A. S. George, "The Dawn of Passkeys: Evaluating a Passwordless Future," *Partners Universal Innovative Research Publication*, vol. 2, no. 1, pp. 202-220, Jan. Feb. 2024, doi: 10.5281/zenodo.10697886.
- [7] T. Oduguwa and A. Arabo, "Passwordless Authentication Using a Combination of Cryptography, Steganography, and Biometrics," *Journal of Cybersecurity and Privacy*, vol. 4, no. 2, pp. 278-297, May 2024, doi: 10.3390/jcp4020014.
- [8] P. Yasasve, K. Niranjan, and Sridharv, "Enhancing Secure Identity Management: A Systematic Review of Passwordless Authentication Techniques," *Anusandhanvallari*, vol. 2026, no. 1, pp. 1324 1331, Apr. 2026.

- [9] M. I. M. Yusop, N. H. Kamarudin, N. H. S. Suhaimi, and M. K. Hasan, "Advancing Passwordless Authentication: A Systematic Review of Methods, Challenges, and Future Directions for Secure User Identity," *IEEE Access*, vol. 13, pp. 13919–13943, Jan. 2025, doi: 10.1109/ACCESS.2025.3528960.
- [10] A. Prasad, "A Comparative Study of Passwordless Authentication," *TechRxiv*, May 2024, doi: 10.36227/techrxiv.171560547.71979752/v1.
- [11] E. H. Spafford, "OPUS: Preventing Weak Password Choices," *Computers & Security*, vol. 11, pp. 273–278, 1992.
- [12] S. Ceti, "The password is dead, long live web authentication," *Computerworld*, Sep. 2018. [Online]. Available: <https://www.computerworld.com.au/article/647205/>
- [13] K. Kovalan et al., "A systematic literature review of the types of authentication safety practices among internet users," *International Journal of Advanced Computer Science and Applications*, vol. 12, no. 7, pp. 829–837, 2021.
- [14] L. Von Ahn, M. Blum, N. Hopper, and J. Langford, "Captcha: Telling humans and computers apart automatically," in *Proc. Eurocrypt*, 2003.
- [15] Jyoti, Shubham, and N. Tiwari, "Beyond Passwords: Trends and Innovations in Passwordless Authentication," *SSRN Electronic Journal*, 2025. [Online]. Available: <https://ssrn.com/abstract=5195701>
- [16] A. Czeski, D. Balfanz, B. A. Ford, J. Howell, and M. Kuang, "Strengthening User Authentication Through Cryptographic Protocols," in *Proc. IEEE Symposium on Security and Privacy*, 2012, pp. 1–15.
- [17] D. Fett, R. Küsters, and G. Schmitz, "The WebAuthn Security Model," in *Proc. IEEE European Symposium on Security and Privacy (EuroS&P)*, 2018, pp. 549–564, doi: 10.1109/EuroSP.2018.00051.
- [18] L. Hanzlik, J. Loss, and B. Wagner, "Token meets Wallet: Formalizing Privacy and Revocation for FIDO2," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2023.
- [19] G. Mustafa et al., "Usability Evaluation of a Push-Based Passwordless Authentication Model Using Public-Key Cryptography," *IET Biometrics*, vol. 2026, Art. no. 5462893, 2026, doi: 10.1049/bme2/5462893.
- [20] K. Bicakci, M. Sekmen, and Y. Uzunay, "Balancing Security and Usability in Enterprise FIDO Passkey Recovery With Peer Assistance," *IEEE Access*, vol. 13, pp. 150415–150425, 2025.
- [21] A. Mahnamfar, K. Bicakci, and Y. Uzunay, "ROSTAM: A passwordless web single sign-on solution mitigating server breaches and integrating credential manager and federated identity systems," *Comput. Secur.*, vol. 139, Art. no. 103739, 2024.
- [22] A. Mitra et al., "TUSH-Key: Transferable User Secrets on Hardware Key," in *Proc. IEEE 30th International Conference on Parallel and Distributed Systems (ICPADS)*, 2024, pp. 176–185.
- [23] C. Wiraatmaja and S. Kasahara, "Scalable Anonymous Authentication Scheme Based on Zero-Knowledge Set-Membership Proof," *Distributed Ledger Technologies: Research and Practice*, vol. 4, no. 1, pp. 1–24, Mar. 2025.
- [24] V. A. Kommuri and K. B. Shaik, "Innovative Passwordless Authentication Approaches in IoT Identity Management," *Majlesi Journal of Electrical Engineering*, vol. 19, no. 2, Jun. 2025, doi: 10.57647/j.mjee.2025.1902.44.
- [25] M. Manoharan, "Multi-Factor Authentication and Passwordless Authentication: The Future of SaaS Security," *IJRCAIT*, vol. 8, no. 1, pp. 509–547, Jan.–Feb. 2025, doi: 10.34218/IJRCAIT_08_01_042.
- [26] Y. Anand and R. Shriram, "Implementation of Secure Passwordless Authentication Using WebAuthn and Public-Key Cryptography," *International Journal of Information Security*, vol. 21, no. 4, pp. 455–468, 2025.
- [27] S. Khan and M. Alqahtani, "Behavioral Risk-Based Authentication for Modern Passwordless Systems," *IEEE Access*, vol. 13, pp. 44521–44539, 2025.